Практическое занятие № 4

ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения»

Цель занятия – изучение ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения» (далее ГОСТ Р 51583-2014), получение практических навыков по разработке технического задания на создание СЗИ в соответствии с установленными требованиями.

Время - 4 часа.

Учебные вопросы:

1. Изучение структуры ГОСТ Р 51583-2014, основных терминов и определений.
2. Общие положения ГОСТ Р 51583-2014.
3. Содержание и порядок выполнения работ на стадиях и этапах создания автоматизированных систем в защищенном исполнении.
4. Содержание и порядок выполнения работ по защите информации о создаваемой автоматизированной системе в защищенном исполнении.

Материально-техническое обеспечение.

Работа выполняется на ПЭВМ типа IBM PC с использованием стандартных функций ОС и дополнительных пакетов программ (Adobe Acrobat Reader ver. 3.0 или выше, либо аналогичные программы для просмотра файлов с расширением pdf).

1 Методические указания студентам по подготовке и проведению практического занятия

1.1 При подготовке к занятию

В период подготовки к практическому занятию студенты получают необходимую литературу в библиотеке университета или из открытых источников сети Интернет и изучают учебные материалы темы, используя литературу, а также конспект лекций. При подготовке к занятию уточнить содержание источников (литературы), рекомендуемой к данному занятию *(пособия и учебники со сроком издания не более 5 лет)*. В ходе изучения материала на практическом занятии студентам рекомендуется ответить на контрольные вопросы, указанные в лекции и в методических рекомендациях по практическому занятию.

1.2 Порядок проведения занятия

Занятие разбивается на два блока по 2 часа каждый.

В первом блоке практического занятия (2 часа) студенты последовательно усваивают учебные вопросы, касающиеся ГОСТ Р 51583-2014, лично отрабатывают контрольные вопросы практического занятия. При необходимости сложные и малопонятные вопросы обсуждаются в группе под руководством преподавателя.

Во втором блоке практического занятия (2 часа) студенты изучают теоретические сведения, касающиеся разработки технического задания на разработку автоматизированных систем в защищенном исполнении (АСЗИ), используя шаблон (Приложение 2) и исходные данные (Приложение 1) для выполнения практического задания оформляют техническое задание в виде документа с титульным листом (включающим грифы утверждения и согласования), разделами в соответствии с рекомендуемой структурой и листом согласования

По окончании занятия студенты оформляют отчет и представляют его преподавателю.

2 Краткие теоретические сведения

Техническое задание (ТЗ) является основным документом, определяющим требования и порядок создания (развития, модернизации) системы защиты информации, в соответствии с которым осуществляется разработка СЗИ и её приемка при вводе в эксплуатацию. ТЗ на создание СЗИ разрабатывается на основе результатов предпроектного обследования и аналитического обоснования необходимости создания системы защиты информации.

В соответствии с ГОСТ 34.602-2020 «Информационные технологии. Комплекс стандартов на автоматизированных систем. Техническое задание на создание автоматизированной системы», техническое задание должно содержать следующие основные разделы:

1. **Общие сведения** – полное наименование системы, наименования заказчика и разработчика, плановые сроки начала и окончания работ, порядок оформления и предъявления результатов.

2. **Назначение и цели создания (развития) системы** – вид автоматизируемой деятельности, перечень объектов автоматизации, цели создания системы.

3. **Характеристика объекта автоматизации** – краткие сведения об объекте, условия эксплуатации, описание функций, информационные связи с другими системами.

4. **Требования к системе** – требования к системе в целом, к функциям (задачам), к видам обеспечения (техническому, программному, информационному, организационному), требования к защите информации от НСД, к эксплуатации, к метрологическому обеспечению.

5. **Состав и содержание работ по созданию (развитию) системы** – перечень стадий и этапов работ, сроки их выполнения, состав исполнителей.

6. **Порядок контроля и приемки системы** – виды, состав, объем и методы

испытаний системы, порядок приемки, оформление результатов.

7. **Требования к составу и содержанию работ по подготовке объекта автоматизации к вводу системы в действие** – перечень мероприятий по подготовке персонала, по приведению помещений в соответствие, по созданию информационной базы.

8. **Требования к документированию** – перечень подлежащих разработке документов, требования к их оформлению и согласованию.

9. **Источники разработки** – перечень документов, использованных при разработке ТЗ.

Для систем защиты информации, создаваемых в составе автоматизированных систем, указанные требования конкретизируются с учетом специфики защищаемой информации.

В соответствии с пунктом 3.13 раздела 3 «Организация работ по защите информации» описанного в документе «Специальные требования и рекомендации по технической защите конфиденциальной информации» (СТР-К), утвержденных приказом Гостехкомиссии России от 30.08.2002 № 282, техническое (частное техническое) задание на разработку СЗИ должно содержать:

- обоснование разработки;
- исходные данные создаваемого (модернизируемого) объекта информатизации в техническом, программном, информационном и организационном аспектах;
- класс защищенности АС;
- ссылку на нормативные документы, с учетом которых будет разрабатываться СЗИ и приниматься в эксплуатацию объект информатизации;
- конкретизацию требований к СЗИ на основе действующих нормативно-методических документов и установленного класса защищенности АС;
- перечень предполагаемых к использованию сертифицированных средств защиты информации;
- обоснование проведения разработок собственных средств защиты информации, невозможности или нецелесообразности использования имеющихся на рынке сертифицированных средств защиты информации;
- состав, содержание и сроки проведения работ по этапам разработки и внедрения;
- перечень подрядных организаций-исполнителей видов работ;
- перечень предъявляемой заказчику научно-технической продукции и документации.

Особенности разработки ТЗ на создание СЗИ ГИС, иных информационных систем органов государственной власти, ИСПДн, ЗОКИИ, АСУ ТП регламентируются соответствующими нормативными и руководящими документами регуляторов в области информационной безопасности.

2.1 Перечень задач, решаемых при разработке технического задания на создание СЗИ

– Формулирование целей и задач создания СЗИ применительно к конкретному объекту информатизации.

– Определение исходных данных о защищаемом объекте: состав и архитектура информационной системы, перечень технических средств и программного обеспечения, категории обрабатываемой информации, количество и категории пользователей.

– Обоснование требований к СЗИ на основе анализа актуальных угроз безопасности информации и установленного класса (уровня) защищенности.

– Определение перечня организационных и технических мер защиты информации, подлежащих реализации в составе СЗИ.

– Обоснование выбора сертифицированных средств защиты информации (СЗИ от НСД, антивирусных средств, межсетевых экранов, СКЗИ) с указанием требуемых классов (уровней доверия).

– Установление состава, содержания и сроков выполнения работ по этапам создания СЗИ.

– Определение порядка приемки СЗИ и требований к составу документации, представляемой по завершении работ.

Оценка ориентировочных материальных, трудовых и финансовых затрат на создание СЗИ.

2.2 Рекомендуемая структура и содержание технического задания на создание СЗИ

Рекомендуемая структура технического задания на создание СЗИ приведена в таблице 1.

Таблица 1 – Рекомендуемая структура ТЗ на создание СЗИ

№ раздела	Наименование раздела	Краткое содержание
1	Общие сведения	Полное наименование объекта информатизации и его условное обозначение, наименование организации-заказчика объекта информатизации, наименование организации-исполнителя, наименование Оператора объекта информатизации, основание для выполнения работ, нормативно-правовая база для проведения работ, сроки начала и окончания работ, источники и порядок финансирования работ.
2	Цель и задачи обеспечения защиты информации	Цель обеспечения защиты информации, задачи обеспечения защиты информации, функции Заказчика и Оператора по обеспечению защиты информации в АС.
3	Общая характеристика объекта информатизации	Назначение АС, функциональные характеристики АС, перечень обрабатываемой информации, описание ИТ-инфраструктуры, описание взаимосвязей АС с иными информационными системами, описание режимов обработки информации в АС, субъекты доступа,

		объекты защиты, классификация объекта информатизации.
4	Требования к системе защиты информации	Требования к системе защиты информации в целом, при этом указываются требования к: мерам защиты информации, составу системы защиты информации, информационному взаимодействию с иными информационными системами и информационно-телекоммуникационными сетями, режимам функционирования, по диагностированию системы защиты информации, модернизации, функциям системы защиты информации. Также описываются подсистем: • защиты от несанкционированного доступа, подсистема антивирусной защиты • обнаружения вторжений • межсетевого экранирования • анализа защищенности • защиты среды виртуализации • криптографической защиты. Требования к видам обеспечения: математическому, информационному, лингвистическому, программному, техническому, метрологическому, организационному и методическому обеспечению. Общие технические требования к системе защиты информации: требования к персоналу, требования к показателям назначения, требования к надежности, требования безопасности, требования к эргономике и технической эстетике, требования к эксплуатации, техническому обслуживанию, ремонту и сохранности компонентов системы защиты информации, требования по сохранности информации при аварии, требования к патентной чистоте, требования к стандартизации и унификации и дополнительные требования.
5	Состав и содержание работ по созданию системы защиты информации	Указываются требования к составу, содержанию и срокам выполнения работ.
6	Порядок разработки системы защиты информации	Указываются состав и содержание работ при разработке СЗИ
7	Порядок контроля и приемки системы защиты информации	Виды, состав, объем и методы испытаний СЗИ, порядок приемки, перечень предъявляемой документации, оформление результатов.
8	Требования к составу и содержанию работ по подготовке объекта автоматизации к вводу системы защиты информации в действие	Требования к составу и содержанию работ по подготовке объекта автоматизации к вводу системы защиты информации в действие
9	Требования к документированию	Перечень подлежащих разработке документов (организационно-распорядительные документы, эксплуатационная документация, отчетные документы),

		требования к их оформлению.
10	Источники разработки	Перечень нормативных правовых актов и методических документов, использованных при разработке ТЗ.

3 Требования к отчёту

Отчёт выполняется каждым студентом индивидуально. Работа должна быть оформлена в электронном виде в формате .doc и распечатана на листах формата А4. На титульном листе указываются: наименование учебного учреждения, наименование дисциплины, название и номер работы, вариант (при наличии), выполнил: фамилия, имя, отчество, группа, проверил: преподаватель ФИО.

Отчет должен содержать:

- титульный лист,
- цель практического занятия,
- отчёт по сайтам: Сайт ФСТЭК России, Сайт Федеральной службы по надзору в сфере связи, информационных технологий и массовых коммуникаций, иные открытые источники из сети Интернет;
- краткие ответы на контрольные вопросы
- оформленное техническое задание в виде документа в соответствии с шаблоном.

4 Контрольные вопросы:

1. Область применения ГОСТ Р 51583-2014.
2. Какая цель создания СЗИ АСЗИ в соответствии с ГОСТ Р 51583-2014?
3. При создании (модернизации) АСЗИ какими требованиями необходимо руководствоваться?
4. Кто участвует в работах по созданию (модернизации) АСЗИ и ее системы ЗИ? Кратко опишите их функционал.
5. Должна ли проводится аттестация АСЗИ? На каком этапе она проводится?
6. Какой комплекс работ обеспечивает создание системы ЗИ АСЗИ?
7. Проведите анализ и поставьте в соответствие комплекс работ по созданию СЗИ АСЗИ (ГОСТ Р 51583-2014) и стадии создания АС (ГОСТ Р 59793-2021 «Информационные технологии (ИТ). Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Стадии создания»). Результаты анализа представьте в виде таблицы:

ГОСТ 51583-2014 «ЗИ. Порядок создания АСЗИ. Общие положения»	ГОСТ Р 59793-2021 ИТ. Комплекс стандартов на АС. АС. Стадии создания	
Комплекс работ	***Стадии создания АС***	***Этапы создания АС***

5 Литература:

5.1 Нормативные правовые акты

5.1.1 Федеральный закон от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации»

5.1.2 Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных»

5.1.3 Федеральный закон от 29.07.2004 № 98-ФЗ «О коммерческой тайне»

5.1.4 Постановление Правительства РФ от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных».

5.1.5 Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных» (с изменениями).

5.1.6 Руководящий документ «Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требования по защите информации» (утв. решением Государственной технической комиссии при Президенте РФ от 30 марта 1992 г.).

5.1.7 Специальные требования и рекомендации по технической защите конфиденциальной информации (СТР-К), утвержденные приказом Гостехкомиссии России от 30.08.2002 № 282.

5.1.8 ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения».

5.1.9 ГОСТ Р 51624-2000 «Защита информации. Автоматизированные системы в защищенном исполнении. Общие требования».

5.1.10 ГОСТ Р 51275-2006 «Защита информации. Объект информатизации. Факторы, воздействующие на информацию. Общие положения».

5.1.11 ГОСТ 34.602-2020 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Техническое задание на создание автоматизированной системы».

5.1.12 Приказ ФСТЭК России от 29.04.2021 № 77 «Об утверждении Порядка организации и проведения работ по аттестации объектов информатизации на соответствие требованиям о защите информации ограниченного доступа, не составляющей государственную тайну»

5.2 Учебная и методическая литература

5.2.1 Информационная безопасность. Техническая защита конфиденциальной информации : учебное пособие / Говядкин Н.В., Кислов Р.И., Лепешкин О.М., Лысов А.В. – СПб: Медиапапир, 2019. – 466 с.

5.2.2 Шаньгин В.Ф. Комплексная защита информации в корпоративных системах : учебное пособие для вузов. – М.: ФОРУМ : ИНФРА-М, 2012. – 592 с.

5.2.3 Хорев А.А. Техническая защита информации : учеб. пособие для

студентов вузов. В 3 т. Т. 1. Технические каналы утечки информации. – М.: НПЦ «Аналитика», 2010. – 436 с.

5.3 Электронные ресурсы

5.3.1 Официальный сайт Федеральной службы по техническому и экспортному контролю (ФСТЭК России) – www.fstec.ru.

5.3.2 Банк данных угроз безопасности информации ФСТЭК России – www.bdu.fstec.ru.

5.3.3 Официальный интернет-портал правовой информации – http://publication.pravo.gov.ru

Приложение 1

Исходные данные для разработки технического задания на создание СЗИ

Информационная система персональных данных «Кадровый учет»

Описание информационной системы персональных данных организации ИСПДн «Кадровый учет»:

Организация: АО УК «Чистый дом», организация осуществляет деятельность по управлению многоквартирными домами, предоставлению жилищно-коммунальных услуг и иные виды деятельности, связанные с эксплуатацией жилищного фонда..

Описание ИСПДн:

Состав:

Персональные данные сотрудников организации:

- фамилия, имя, отчество;
- дата и место рождения;
- пол;
- сведения об образовании;
- сведения о предыдущем месте работы;
- адреса регистрации и фактического проживания;
- номера контактных телефонов;
- индивидуальный номер налогоплательщика;
- номер страхового свидетельства пенсионного страхования;
- номер полиса обязательного медицинского страхования;
- данные водительского удостоверения.

В информационной системе одновременно обрабатываются данные 98 субъектов персональных данных (сотрудников) в пределах Организации.

2. Имеется три автоматизированных рабочих места (АРМ) пользователей, сетевой принтер, сервер, коммутационное оборудование.

Топология: АРМ и сервер составляют сегмент корпоративной вычислительной сети (см. схему).

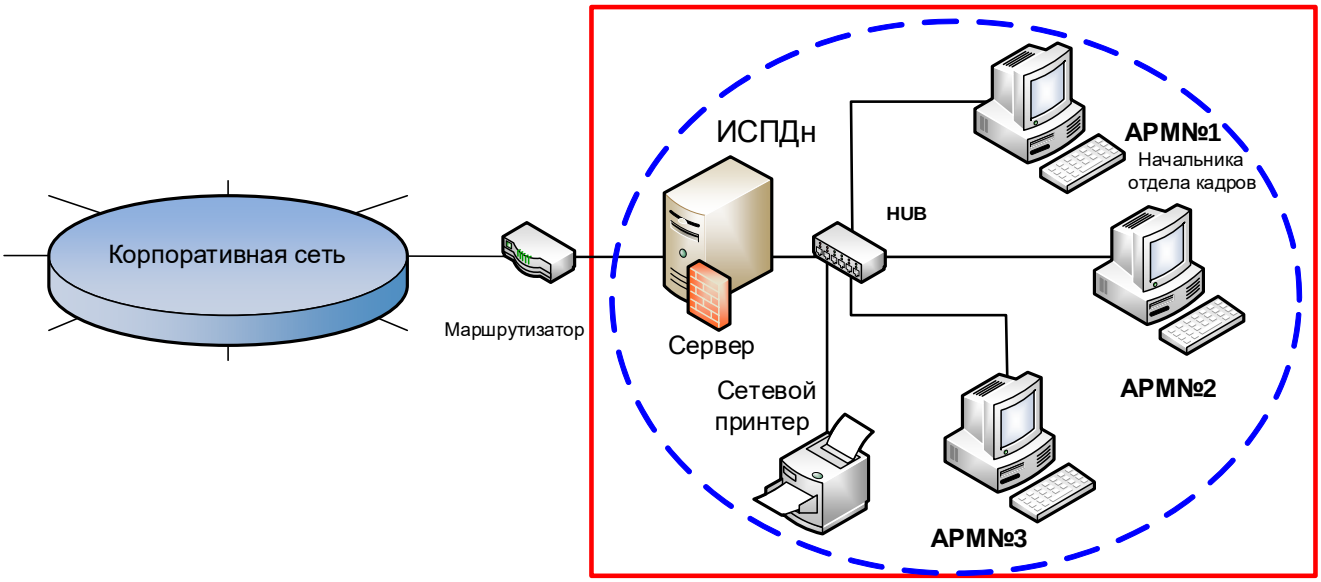


Схема ИСПД АО УК «Чистый дом»

<u>Корпоративная сеть Организации не имеет подключение к сетям связи общего пользования и сетям международного информационного обмена</u>.

В состав каждого АРМ входят два жёстких диска, на первом установлена операционная система, прикладное программное обеспечение и общедоступная справочная информация, на втором - информация, составляющая персональные данные сотрудников Организации.

1. Комплект АРМ № 1-3 (см. схему):
   - системный блок CityTime № JFBNCGRHDBG01-03,
   - монитор Samsung N710 – серийный номер KBMHDFGFD01-03,
   - клавиатура Genius серийный номер WESDC01-03,
   - графический манипулятор (мышь) Genius серийный номер DSDA01-03.

Состав ПО для обработки ПД:

- Клиентская часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОРП) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

- Диспетчер печати.

2. В состав сервера входят три жестких диска, на первом установлена операционная система, прикладное программное обеспечение, второй и третий объединены в RAID массив, в котором хранится информация, составляющая персональные данные сотрудников Организации.

Комплект сервера:

- системный блок CityTime Prof № SDHBKYDHG04,
- монитор Samsung N710 – серийный номер JDHDNGHD04,
- клавиатура Genius серийный номер DGFU04,
- графический манипулятор Genius серийный номер HBDR04.

Состав ПО для обработки ПД:
- Серверная часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОРП) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».
2. Диспетчер печати.

Сервер и коммуникационное оборудование установлены в типовой стойке.
Сетевой принтер HP LaserJet P2015 серийный номер DEFVBG.
Коммутатор: Коммутатор Cisco WS-C2960CX-8TC-L.
Маршрутизатор: Маршрутизатор Cisco Small Business RV340-K8-RU.

1. Технология обработки персональных данных:

Обработка персональных данных сотрудников включает весь перечень действий, включая сбор, запись, систематизацию, накопление, хранение, уточнение (обновление, изменение), извлечение, использование, передачу (распространение, предоставление, доступ), обезличивание, блокирование, удаление, уничтожение персональных данных.

К работе на АРМ допущены сотрудники отдела кадров и заместитель директора.

Полный доступ ко всей информации на АРМ и сервере имеют заместитель директора и начальник отдела кадров.

Сотрудники отдела кадров имеют полный доступ только к каталогу «Личные дела», размещённой на диске №2 своего АРМ, и только на чтение информации из каталога «Личные дела» на сервере.

Системный администратор сегмента сети не имеет доступа к информации, составляющей персональные данные. Имеет права на инсталляцию, настройку программного обеспечения, программных (программно-аппаратных) средств защиты сервера и АРМ № 1-3.

Режим работы - одновременный.

Расположение: АО УК «Чистый дом», г. Ростов-на-Дону, ул. Строителей, дом № 15, офис 306, расположено на третьем этаже 3-х этажного здания. На 1-ом и 2-ем этажах расположены сторонние организации. Имеется общая охраняемая территория. Допуск посторонних лиц и автомашин только с согласия руководителя Организации и руководителей сторонних организаций. Доступ в помещение ограничен распорядительными актами Организации и автоматизированной системой контроля и управления доступа. Перечень сотрудников, имеющих доступ к конфиденциальной информации, определен приказом руководителя АО УК «Чистый дом».

Контролируемая зона (КЗ) ЗП для носимых ТСР проходит по ограждающим конструкциям третьего этажа, за исключением лестницы на верхние этажи. Исследуемое ЗП - переговорная – не граничит с КЗ для возимых ТСР, а для носимых ТСР граничит по потолку. КЗ для возимых ТСР проходит по периметру внешнего ограждения (забора) организации. Границей КЗ для

стационарных ТСР является: с севера – жилое здание (расстояние 250 м.), с юга - территория организации ООО «Интеко» (расстояние 189 м.), с запада – здание бассейна «Волна» (расстояние 176 м.), с востока - жилое здание, находящееся через парк (расстояние 1020 м.). Средства звукоусиления отсутствуют.

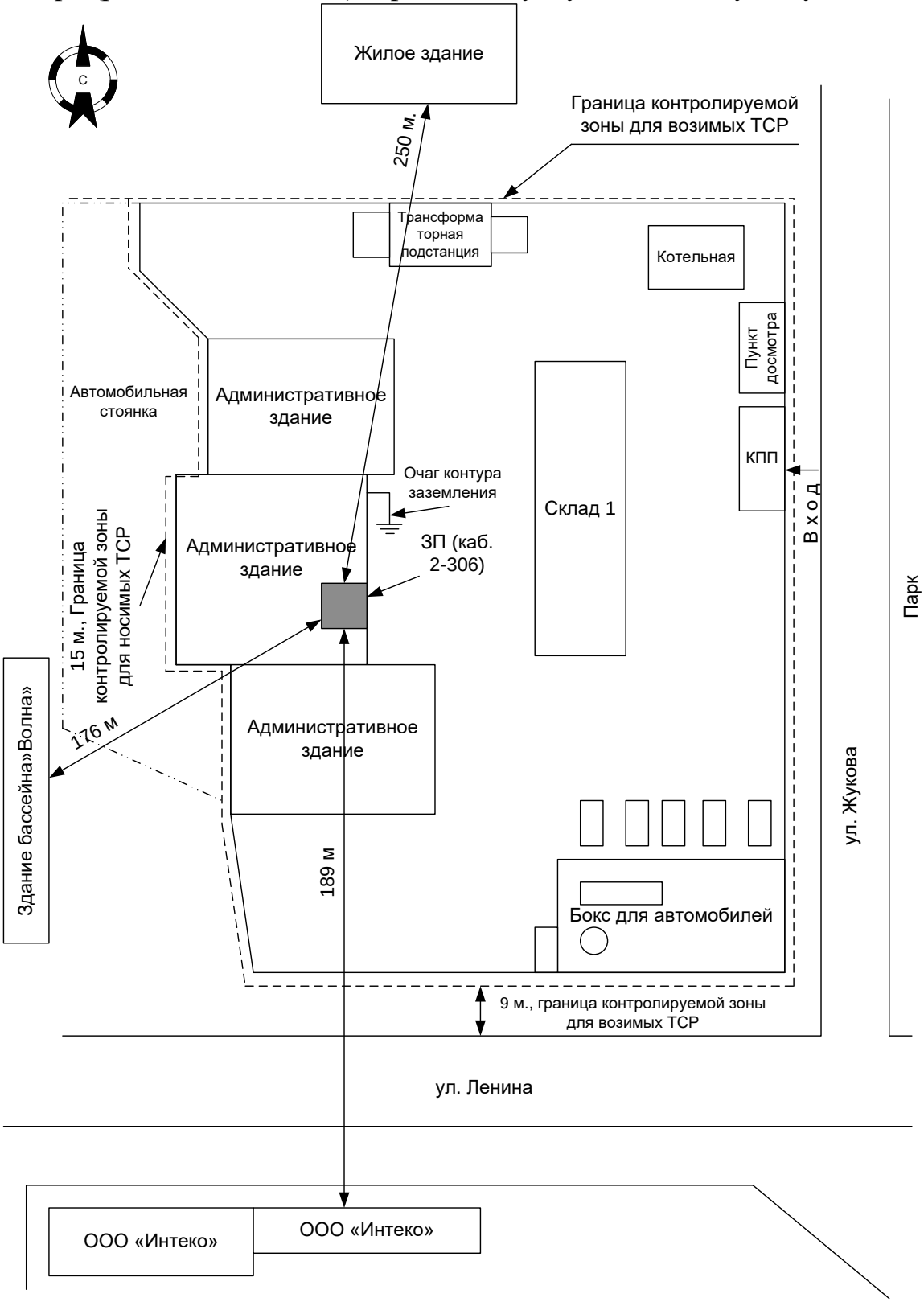


Схема границ контролируемых зон АО УК «Чистый дом»

Приложение 2
Шаблон технического задания на создание системы защиты информации

УТВЕРЖДАЮ[1]

_____

(должность руководителя организации)

_____

(подпись)

«_____» _____ 202 ____г.

Объект информатизации
«Информационная система обработки персональных данных «Кадровый учет» акционерного общества «Управляющая компания «Чистый дом»»

ТЕХНИЧЕСКОЕ ЗАДАНИЕ
на создание системы защиты информации
на ___ листах

202_ г.

[1] Техническое (частное техническое) задание на разработку СЗИ подписывается разработчиком, согласовывается со службой безопасности предприятия-заказчика, подрядными организациями и утверждается заказчиком. Перечень сведений конфиденциального характера составляется заказчиком объекта информатизации и утверждается его руководителем.

Перечень сокращений и обозначений

В настоящем техническом задании применяются следующие сокращения:

АВЗ	–	антивирусная защита
АРМ	–	автоматизированное рабочее место
ГИС	–	государственная информационная система
ИС	–	информационная система
ИОД	–	информация ограниченного доступа
ИСПДн	–	информационная система персональных данных
КЗ	–	контролируемая зона
ЛВС	–	локальная вычислительная сеть
НСД	–	несанкционированный доступ
ОС	–	операционная система
ПДн	–	персональные данные
ПО	–	программное обеспечение
СКЗИ	–	средство криптографической защиты информации
СЗИ	–	система защиты информации
СрЗИ	–	средство защиты информации
ТС	–	техническое средство
ФСБ России	–	Федеральная служба безопасности Российской Федерации
ФСТЭК России	–	Федеральная служба по техническому и экспортному контролю

Содержание

1 Общие сведения
1.1 Полное наименование объекта информатизации и его условное обозначение
1.2 Наименование организации-заказчика объекта информатизации, наименование организации-исполнителя, наименование Оператора объекта информатизации
1.3 Основание для выполнения работ
1.4 Нормативно-правовая база для проведения работ
1.5 Сроки начала и окончания работ
1.6 Источники и порядок финансирования работ
2 Цель и задачи обеспечения защиты информации
2.1 Цель обеспечения защиты информации
2.2 Задачи обеспечения защиты информации
2.3 Функции Заказчика и Оператора по обеспечению защиты информации в Системе
3 Общая характеристика объекта информатизации
3.1 Назначение Системы
3.2 Функциональные характеристики Системы
3.3 Перечень обрабатываемой информации
3.4 Описание ИТ-инфраструктуры
3.5 Описание взаимосвязей Системы с иными информационными системами
3.6 Описание режимов обработки информации в Системе
3.7 Субъекты доступа
3.8 Объекты защиты
3.9 Классификация объекта информатизации
4 Требования к системе защиты информации
4.1 Требования к системе защиты информации в целом
4.1.1 Требования к мерам защиты информации
4.1.2 Требования к составу системы защиты информации
4.1.3 Требования к информационному взаимодействию с иными информационными системами и информационно-телекоммуникационными сетями
4.1.4 Требования к режимам функционирования
4.1.5 Требования по диагностированию системы защиты информации
4.1.6 Требования к модернизации
4.2 Требования к функциям системы защиты информации
4.2.1 Подсистема защиты от несанкционированного доступа
4.2.2 Подсистема антивирусной защиты
4.2.3 Подсистема обнаружения вторжений
4.2.4 Подсистема межсетевого экранирования
4.2.5 Подсистема анализа защищенности
4.2.6 Подсистема защиты среды виртуализации
4.2.7 Подсистема криптографической защиты
4.3 Требования к видам обеспечения
4.3.1 Требования к математическому обеспечению
4.3.2 Требования к информационному обеспечению
4.3.3 Требования к лингвистическому обеспечению
4.3.4 Требования к программному обеспечению
4.3.5 Требования к техническому обеспечению
4.3.6 Требования к метрологическому обеспечению
4.3.7 Требования к организационному обеспечению

4.3.8 Требования к методическому обеспечению
4.4 Общие технические требования к системе защиты информации
4.4.1 Требования к персоналу
4.4.2 Требования к показателям назначения
4.4.3 Требования к надежности
4.4.4 Требования безопасности
4.4.5 Требования к эргономике и технической эстетике
4.4.6 Требования к эксплуатации, техническому обслуживанию, ремонту и сохранности компонентов системы защиты информации
4.4.7 Требования по сохранности информации при аварии
4.4.8 Требования к патентной чистоте
4.4.9 Требования к стандартизации и унификации
4.4.10 Дополнительные требования
5 Состав и содержание работ по созданию системы защиты информации
5.1 Требования к составу работ
5.2 Требования к содержанию работ
5.3 Сроки выполнения работ
6 Порядок разработки системы защиты информации
7 Порядок контроля и приемки системы защиты информации
7.1 Общие требования к порядку контроля и приемки системы защиты информации
7.1.1 Предварительные испытания
7.1.2 Опытная эксплуатация
7.1.3 Приемочные испытания
8 Требования к составу и содержанию работ по подготовке объекта автоматизации к вводу системы защиты информации в действие
9 Требования к документированию
9.1 Перечень подлежащих разработке документов
9.2 Вид представления и количество документов
9.3 Требования по использованию единой системы конструкторской документации и единой системы программной документации при разработке документов
10 Источники разработки

1 Общие сведения

1.1 Полное наименование объекта информатизации и его условное обозначение

Полное наименование системы: *«Информационная система обработки персональных данных «Кадровый учет» акционерного общества «Управляющая компания «Чистый дом»»*[2]

Условное обозначение: *Система, ИСПДн.*

1.2 Наименование организации-заказчика объекта информатизации, наименование организации-разработчика, наименование Оператора объекта информатизации

Разработчик: *Закрытое акционерное общество «Центр безопасности информационных технологий» (ЗАО «ЦБИТ»)*

Юридический адрес: *г. Ростов-на-Дону, ул. Ростовская, д. 16.*

Заказчик, Оператор Системы: *акционерное общество «Управляющая компания «Чистый дом»»*

Юридический адрес: *344000, г. Ростов-на-Дону, ул. Строителей, дом № 15, офис 306.*

1.3 Основание для выполнения работ

Основанием для выполнения работ является договор № 655433-Д от 31.01.2025.

1.4 Нормативно-правовая база для проведения работ

Федеральный закон от 27.07.2006 № 149-ФЗ "Об информации, информационных технологиях и о защите информации".

Федеральный закон от 27.07.2006 № 152-ФЗ "О персональных данных".

Указ Президента Российской Федерации от 06.03.1997 № 188 "Об утверждении Перечня сведений конфиденциального характера".

Постановление Правительства Российской Федерации от 01.11.2012 № 1119 "Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных".

Приказ ФСТЭК России от 13.02.2013 № 21 "Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных".

Приказ ФСБ России от 10.07.2017 № 378 "Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищенности".

ГОСТ 59853-2021 " Информационные технологии. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Термины и определения ".

ГОСТ 34.201-20 "Информационная технология. Комплекс стандартов на автоматизированные системы. Виды, комплектность и обозначение документов при создании автоматизированных систем".

[2] Здесь и далее по тексту ТЗ курсивом приведено возможное наполнение соответствующего раздела (подраздела) ТЗ

ГОСТ 34.601-90 "Информационная технология. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Стадии создания".

ГОСТ 59.792-21 "Информационная технология. Виды испытаний автоматизированных систем".

ГОСТ Р 51583-2014 "Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения".

Методика оценки угроз безопасности информации, утвержденная ФСТЭК России 05.02.2021 (Информационное сообщение ФСТЭК России от 15.02.2021 №240/22/690).

1.5 Сроки начала и окончания работ

Начало и окончание работ определяется владельцем объекта информатизации на этапе реализации.

1.6 Источники и порядок финансирования работ

Определяется владельцем объекта информатизации на этапе реализации.

2 Цель и задачи обеспечения защиты информации

2.1 Цель обеспечения защиты информации

Основными целями обеспечения защиты информации являются:

– *нейтрализация угроз безопасности информации в Системе в процессе обработки информации;*

– *выполнение требований законодательных и нормативных правовых актов Российской Федерации, руководящих и методических документов ФСТЭК России, регламентирующих вопросы защиты информации, обрабатываемой в ИСПДн.*

2.2 Задачи обеспечения защиты информации

Задачами, решаемыми СЗИ, являются:

– *предотвращение неправомерного доступа, копирования, предоставления или распространения ИОД (обеспечение конфиденциальности информации);*

– *исключение неправомерного уничтожения или модифицирования ИОД (обеспечение целостности информации);*

– *исключение неправомерного блокирования ИОД (обеспечение доступности информации).*

2.3 Функции Заказчика и Оператора по обеспечению защиты информации в Системе

Заказчик и Оператор должны выполнять следующие функции по обеспечению защиты информации в Системе:

– *принятие решения о необходимости создания СЗИ Системы;*

– *организация работ по созданию СЗИ Системы;*

– *выполнение требований по защите информации в ходе создания, эксплуатации и вывода из эксплуатации Системы;*

– *контроль нормативно-правой базы в области защиты информации;*

– *контроль за обеспечением уровня защищенности Системы.*

3 Общая характеристика объекта информатизации

3.1 Назначение Системы

Система предназначена для обработки персональных данных сотрудников АО УК «Чистый дом».

3.2 Функциональные характеристики Системы

Система включает в себя следующие ИС:

- *1С:Зарплата и кадры 8.*

3.3 Перечень обрабатываемой информации

В Системе планируется обработка общедоступной информации и ИОД, не содержащей сведения, составляющие государственную тайну, включая ПДн.

В Системе обрабатывается следующая ИОД, включая ПДн:

- *фамилия, имя, отчество;*
- *дата и место рождения;*
- *пол;*
- *сведения об образовании;*
- *сведения о предыдущем месте работы;*
- *адреса регистрации и фактического проживания;*
- *номера контактных телефонов;*
- *индивидуальный номер налогоплательщика;*
- *номер страхового свидетельства пенсионного страхования;*
- *номер полиса обязательного медицинского страхования;*
- *данные водительского удостоверения.*

Полный перечень обрабатываемых в системе ПДн определен в Положении о порядке обработки и защите ПДн.

3.4 Описание ИТ-инфраструктуры

Система представляет собой совокупность серверного оборудования, АРМ, сетевого оборудования, а также общего и прикладного ПО, реализующего функции по обработке информации.

Компоненты системы располагаются по следующему адресу:

- *г. Ростов-на-Дону, ул. Строителей, дом № 1;*

Система не имеет подключение к сети международного обмена "Интернет".

Система не осуществляет взаимодействие с ГИС.

АРМ пользователей представляют собой физические рабочие места.

В состав технических средств Системы будет входить:

- *сервер;*
- *АРМ пользователей;*
- *активное и пассивное сетевое оборудование;*
- *устройства печати (многофункциональное устройство, принтер);*
- *программно-аппаратные СрЗИ.*

Информация о перечне и типах (ролях) сервера с указанием места размещения сервера и рабочих станций представлена в таблицах №№ 1 и 2 соответственно.

Таблица 1 – Информация о серверном оборудовании

№ п/п	Тип сервера	Роль	Место размещения	IP-адрес
1.	Физический	1С:Зарплата и кадры 8	г. Ростов-на-Дону, ул. Строителей, д. № 1	192.168.0.1

Таблица 2 – Информация о типовых рабочих станциях

№ п/п	Тип	Тип ОС	Роль	Количество
1.	Физический	MS Windows	АРМ пользователя	3

Парк коммутационного оборудования состоит из набора как управляемых, так и неуправляемых коммутаторов Cisco, в промышленном и домашнем исполнениях. Включение коммутационного оборудование в информационную инфраструктуру выполнено каскадным методом.

В составе сетевой инфраструктуры отсутствуют Wi-Fi точки доступа.

Информация о применяемом ПО представлена в таблице 3.

Таблица 3 – Информация о применяемом программном обеспечении

№ п/п	Наименование	Место установки	Назначение
1.	1С "Предприятие" 8.3.23	Физический сервер	СУБД
2.	Adobe Genuine Service вер. 8.4.0.63	АРМ пользователей	Офисный пакет
3.	Adobe Acrobat XI Pro вер. 11.0.23		Офисный пакет
4.	1С:Предприятие 8 Тонкий клиент (8.3.23.1782) вер. 8.3.23.1782		СУБД
5.	Microsoft Office стандартный 2016 - ru-ru вер. 16.0.11929.20300		Офисный пакет
6.	WinRAR 6.24 (64-разрядная) вер. 6.24.0		Архивтаор
7.	ABBYY FineReader PDF 15 вер. 15.0.3887		Офисный пакет
8.	Google Chrome вер. 126.0.6478.127		Браузер
9.	Mozilla Firefox (x64 ru) вер. 124.0.1		Браузер

Структурная схема Системы с указанием информационных связей между компонентами Системы представлена на рисунке 1.

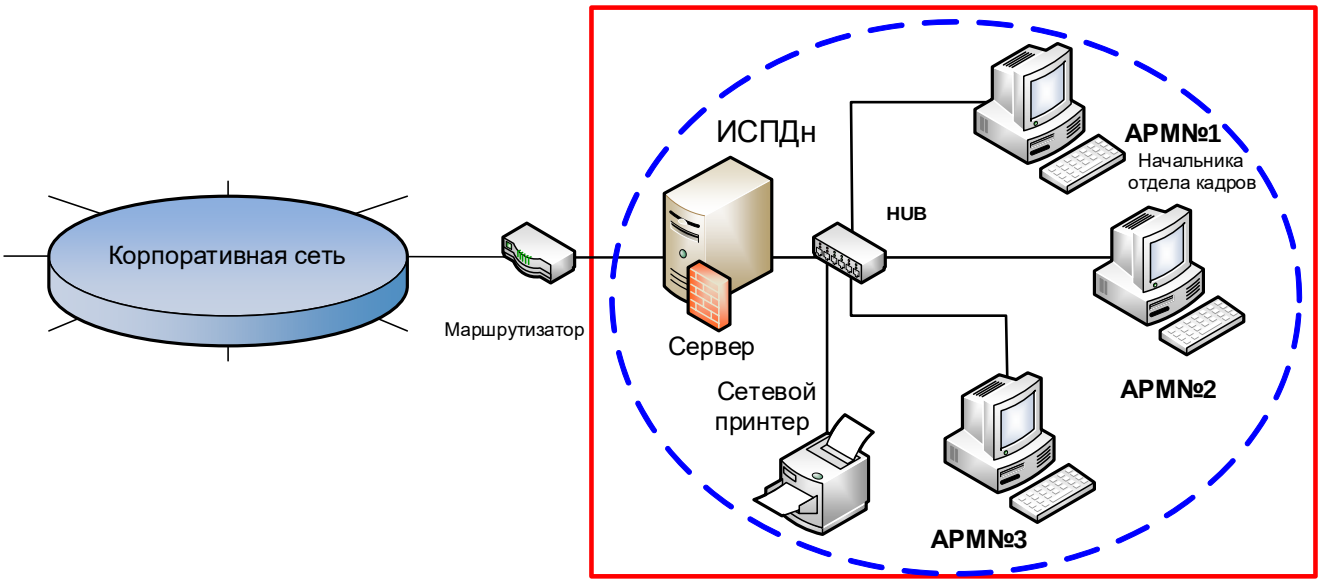


Рисунок 1 – Структурная схема Системы с указанием информационных связей между компонентами Системы, информационно-телекоммуникационной сетью Интернет

3.5 Описание взаимосвязей Системы с иными информационными системами

Система не осуществляет взаимодействие с ГИС.

3.6 Описание режимов обработки информации в Системе

Общесистемное и прикладное ПО должно работать в соответствии с установленными режимами функционирования Системы.

В отношении Системы предусмотрены следующие режимы функционирования:

– *штатный режим, предусматривающий непрерывную круглосуточную работу серверного сегмента Системы (с реализацией всех необходимых автоматизированных процессов сбора и обработки информации);*

– *сервисный режим, предназначенный для проведения необходимых технологических работ (реконфигурации подсистем и пополнения их новыми компонентами, проведения мероприятий по техническому обслуживанию и диагностированию работоспособности элементов Системы, созданию резервных копий ПО и баз данных оперативного хранения для поддержки способности Системы к восстановлению в аварийных ситуациях и т.д.);*

– *автономный режим, гарантирующий сохранение минимально достаточной функциональности Системы при нарушении горизонтальных или вертикальных связей между ее структурными компонентами.*

3.7 Субъекты доступа

Пользователи в Системе разделяются на категории, различающиеся правами доступа к информационно-функциональным ресурсам Системы (дискреционный и ролевой методы управления доступом).

Доступ к ресурсам Системы осуществляют следующие категории лиц (субъекты доступа):

– *администратор безопасности (работник АО УК «Чистый дом», ответственный за обеспечение безопасности информации);*

– *системный администратор (работник АО УК «Чистый дом», ответственный за функционирование ОС, общесистемного и прикладного ПО);*

– *пользователи Системы (внутренние) – работники АО УК «Чистый дом».*

3.8 Объекты защиты

К основным объектам защиты в Системе относятся:

– *ИОД, обрабатываемая в Системе, включая ПДн;*

– *программно-технические средства: сетевое оборудование, серверы, в том числе виртуальные, АРМ (пользователей, администраторов);*

– *общесистемное и прикладное ПО;*

– *телекоммуникационное оборудование, в том числе ПО для управления телекоммуникационным оборудованием;*

– *каналы связи внутри и за пределами контролируемой зоны;*

– *помещения (серверные), в которых располагается комплекс программно-технических средств Системы;*

– *СрЗИ, в том числе криптографические.*

3.9 Классификация объекта информатизации

Согласно постановлению Правительства Российской Федерации от 01.11.2012 № 1119 "Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных", уровень защищенности Системы определяется исходя из категории и количества ПДн, а также актуальности угроз различных типов. Оценка данных характеристик относительно Системы приведена в таблице 4.

Таблица 4 – Характеристики Системы

Характеристика	*Значение*	*Примечание*
Субъекты ПДн	*менее 100 000*	*являются сотрудниками Оператора*
Категории ПДн	*иные*	*Система не обрабатывает, биометрические, специальные и общедоступные категории ПДн*
Тип актуальных угроз	*третий*	*т.к. актуальны угрозы, не связанные с наличием недокументированных (недекларированных) возможностей в системном и прикладном ПО, используемом в Системе*

Таким образом к Системе предъявляются требования по защите персональных данных третьего уровня защищенности (УЗ3).

4 Требования к системе защиты информации

4.1 Требования к системе защиты информации в целом

Безопасность информации, обрабатываемой в Системе, должна обеспечиваться на всех технологических этапах обработки информации и во всех режимах функционирования ТС Системы.

4.1.1 Требования к мерам защиты информации

Формирование требований осуществляется итерационно и включает в себя:

- *определение базового набора мер защиты информации;*
- *адаптацию базового набора мер защиты информации применительно к структурно-функциональным характеристикам Системы, информационным технологиям, особенностям функционирования Системы (в том числе предусматривающую исключение из базового набора мер защиты информации мер, непосредственно связанных с информационными технологиями, не используемыми в Системе, или структурно-функциональными характеристиками, не свойственными Системе);*
- *уточнение адаптированного базового набора мер защиты информации с учетом не выбранных ранее мер защиты информации, в результате чего определяются меры защиты информации, обеспечивающие блокирование (нейтрализацию) всех угроз безопасности информации, включенных в Модель угроз;*
- *дополнение уточненного адаптированного базового набора мер защиты информации мерами, обеспечивающими выполнение требований о защите информации, установленными иными нормативными правовыми актами в области защиты информации.*

Базовый набор мер, необходимый для обеспечения безопасности ПДн при их обработке в ИСПДн, соответствующий третьему уровню защищенности ПДН, определен в приказе ФСТЭК России от 18.02.2013 № 21 "Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных".

Адаптация базового набора мер осуществляется в соответствии со структурно-функциональными характеристиками, определенными в разделе 3 настоящего Технического задания.

В частности, в Системе не применяются следующие информационные технологии для обработки информации:

- *технологии мобильного кода;*
- *технологии виртуализации;*
- *технологии беспроводной передачи данных*
- *передача речи;*
- *передача видеоинформации;*
- *голосовой ввод информации;*
- *терминальный доступ;*
- *технологии машинного обучения;*
- *Система не является грид-системой;*
- *технологии Big data;*
- *не используются видеокамеры, микрофоны и иные периферийные устройства;*

– Система не является автоматизированной системой управления технологическими процессами и не использует программные логические контроллеры.

Уточнение адаптированного базового набора мер защиты информации осуществляется с учетом актуальных угроз безопасности информации, определенных в модели угроз безопасности информации, обрабатываемой Системе.

Учитывая изложенное, был произведен выбор мер защиты информации, соответствующий 3 уровню защищенности персональных данных, структурно-функциональным характеристикам Системы и актуальным угрозам безопасности информации, отраженных в таблице 5.

Таблица 6 – Дополненный уточненный адаптированный базовый набор мер защиты информации

Условное обозначение и номер меры	*Содержание мер по обеспечению безопасности ИОД*
I. Идентификация и аутентификация субъектов доступа и объектов доступа (ИАФ)	
ИАФ.1	*Идентификация и аутентификация пользователей, являющихся работниками Оператора*
ИАФ.3	*Управление идентификаторами, в том числе создание, присвоение, уничтожение идентификаторов*
ИАФ.4	*Управление средствами аутентификации, в том числе хранение, выдача, инициализация, блокирование средств аутентификации и принятие мер в случае утраты и (или) компрометации средств аутентификации*
ИАФ.5	*Защита обратной связи при вводе аутентификационной информации*
ИАФ.6	*Идентификация и аутентификация пользователей, не являющихся работниками Оператора (внешних пользователей)*
II. Управление доступом субъектов доступа к объектам доступа (УПД)	
УПД.1	*Управление (заведение, активация, блокирование и уничтожение) учетными записями пользователей, в том числе внешних пользователей*
УПД.2	*Реализация необходимых методов (дискреционный, мандатный, ролевой или иной метод), типов (чтение, запись, выполнение или иной тип) и правил разграничения доступа*
УПД.3	*Управление (фильтрация, маршрутизация, контроль соединений, однонаправленная передача и иные способы управления) информационными потоками между устройствами, сегментами ИС, а также между ИС*
УПД.4	*Разделение полномочий (ролей) пользователей, администраторов и лиц, обеспечивающих функционирование ИС*
УПД.5	*Назначение минимально необходимых прав и привилегий пользователям, администраторам и лицам, обеспечивающим функционирование ИС*
УПД.6	*Ограничение неуспешных попыток входа в ИС (доступа к ИС)*
УПД.10	*Блокирование сеанса доступа в ИС после установленного времени бездействия (неактивности) пользователя или по его запросу*
УПД.11	*Разрешение (запрет) действий пользователей, разрешенных до идентификации и аутентификации*
УПД.13	*Реализация защищенного удаленного доступа субъектов доступа к объектам доступа через внешние информационно-телекоммуникационные сети*
УПД.14	*Регламентация и контроль использования в ИС технологий беспроводного доступа*
УПД.15	*Регламентация и контроль использования в ИС мобильных ТС*
УПД.16	*Управление взаимодействием с ИС сторонних организаций (внешние ИС)*
IV. Защита машинных носителей персональных данных (ЗНИ)	

Условное обозначение и номер меры	*Содержание мер по обеспечению безопасности ИОД*
ЗНИ.8	*Уничтожение (стирание) или обезличивание ПДн на машинных носителях при их передаче между пользователями, в сторонние организации для ремонта или утилизации, а также контроль уничтожения (стирания) или обезличивания*
V. Регистрация событий безопасности (РСБ)	
РСБ.1	*Определение событий безопасности, подлежащих регистрации, и сроков их хранения*
РСБ.2	*Определение состава и содержания информации о событиях безопасности, подлежащих регистрации*
РСБ.3	*Сбор, запись и хранение информации о событиях безопасности в течение установленного времени хранения*
РСБ.7	*Защита информации о событиях безопасности*
VI. Антивирусная защита (АВЗ)	
АВЗ.1	*Реализация АВЗ*
АВЗ.2	*Обновление базы данных признаков вредоносных компьютерных программ (вирусов)*
VII. Обнаружение вторжений (СОВ)	
СОВ.1	*Обнаружение вторжений*
СОВ.2	*Обновление базы решающих правил*
VIII. Контроль (анализ) защищенности информации (АНЗ)	
АНЗ.1	*Выявление, анализ уязвимостей ИС и оперативное устранение вновь выявленных уязвимостей*
АНЗ.2	*Контроль установки обновлений ПО, включая обновление ПО СрЗИ*
АНЗ.3	*Контроль работоспособности, параметров настройки и правильности функционирования ПО и СрЗИ*
АНЗ.4	*Контроль состава ТС, ПО и СрЗИ*
XI. Защита среды виртуализации (ЗСВ)	
ЗСВ.1	*Идентификация и аутентификация субъектов доступа и объектов доступа в виртуальной инфраструктуре, в том числе администраторов управления средствами виртуализации*
ЗСВ.2	*Управление доступом субъектов доступа к объектам доступа в виртуальной инфраструктуре, в том числе внутри виртуальных машин*
ЗСВ.3	*Регистрация событий безопасности в виртуальной инфраструктуре*
ЗСВ.9	*Реализация и управление АВЗ в виртуальной инфраструктуре*
ЗСВ.10	*Разбиение виртуальной инфраструктуры на сегменты (сегментирование виртуальной инфраструктуры) для обработки ПДн отдельным пользователем и (или) группой пользователей*
XII. Защита технических средств (ЗТС)	
ЗТС.3	*Контроль и управление физическим доступом к ТС, СрЗИ, средствам обеспечения функционирования, а также в помещения и сооружения, в которых они установлены, исключающие несанкционированный физический доступ к средствам обработки информации, СрЗИ и средствам обеспечения функционирования ИС, в помещения и сооружения, в которых они установлены*
ЗТС.4	*Размещение устройств вывода (отображения) информации, исключающее ее несанкционированный просмотр*
XIII. Защита ИС, ее средств, систем связи и передачи данных (ЗИС)	

Условное обозначение и номер меры	*Содержание мер по обеспечению безопасности ИОД*
ЗИС.3	*Обеспечение защиты ПДн от раскрытия, модификации и навязывания (ввода ложной информации) при ее передаче (подготовке к передаче) по каналам связи, имеющим выход за пределы КЗ, в том числе беспроводным каналам связи*
ЗИС.20	*Защита беспроводных соединений, применяемых в ИС*
XV. Управление конфигурацией ИС и системы защиты ПДн (УКФ)	
УКФ.1	*Определение лиц, которым разрешены действия по внесению изменений в конфигурацию ИС и системы защиты ПДн*
УКФ.2	*Управление изменениями конфигурации ИС и системы защиты ПДн*
УКФ.3	*Анализ потенциального воздействия планируемых изменений в конфигурации ИС и системы защиты ПДн на обеспечение защиты ПДн и согласование изменений в конфигурации ИС с должностным лицом (работником), ответственным за обеспечение безопасности ПДн*
УКФ.4	*Документирование информации (данных) об изменениях в конфигурации ИС и системы защиты ПДн*

4.1.2 Требования к составу системы защиты информации

В состав СЗИ должны входить следующие подсистемы:

- *подсистема защиты от НСД;*
- *подсистема АВЗ;*
- *подсистема обнаружения вторжений;*
- *подсистема межсетевого экранирования;*
- *подсистема анализа защищенности;*
- *подсистема криптографической защиты каналов связи.*

Также в состав СЗИ должен быть включен комплекс организационно-технических мероприятий.

Для обеспечения защиты информации, содержащейся в Системе, должны применяться СрЗИ, прошедшие оценку соответствия в форме обязательной сертификации на соответствие требованиям по безопасности информации, соответствующие 6 или более высокому уровню доверия.

Кроме того, должны применяться СрЗИ 6 класса и средства вычислительной техники не ниже 5 класса.

Функции безопасности СрЗИ должны обеспечивать выполнение мер защиты информации, содержащихся в таблице 6.

4.1.3 Требования к информационному взаимодействию с иными информационными системами и информационно-телекоммуникационными сетями

Информационное взаимодействие с иными информационными системами и информационно-телекоммуникационными сетями Системой не осуществляется.

4.1.4 Требования к режимам функционирования

Система должна функционировать в следующих режимах:

- *штатный режим функционирования, в котором Система выполняет свои функции в полном объеме;*

– *режим регламентного обслуживания, в котором Система не выполняет свои функции или выполняет их не в полном объеме ввиду проведения работ по регламентному обслуживанию;*

– *режим аварийного обслуживания, в котором Система не выполняет свои функции или выполняет их не в полном объеме ввиду проведения работ по устранению внештатных сбоев и аварий.*

Основным для СЗИ Системы является штатный режим функционирования, обеспечивающий возможность эксплуатации Системы в полном объеме.

В штатном режиме функционирования Системы:

– *обеспечивается возможность работы пользователей с Системой в диалоговом режиме 24 часа в сутки 7 дней в неделю (24×7);*

– *исправно работает оборудование, составляющее комплекс ТС;*

– *исправно функционирует общесистемное и прикладное ПО Системы.*

Для обеспечения штатного режима функционирования Системы, необходимо выполнять требования и выдерживать условия эксплуатации ПО и комплекса ТС Системы, которые должны быть описаны в соответствующих документах на СЗИ Системы.

В режиме регламентного обслуживания СЗИ Системы должна обеспечивать возможность проведения работ по ее техническому обслуживанию и модернизации. В режим регламентного обслуживания СЗИ Системы переходит в следующих случаях:

– *возникновение необходимости модернизации аппаратно-программного комплекса;*

– *возникновение необходимости проведения технического обслуживания.*

Общее время проведения работ по регламентному обслуживанию Системы не должно превышать 0,5 % от общего времени работы Системы в штатном режиме (4 часа от 720 часов в месяц).

Режим аварийного обслуживания Системы характеризуется отказом одного или нескольких компонентов программного и (или) технического обеспечения. В режиме аварийного обслуживания СЗИ Системы должна обеспечивать возможность проведения работ по устранению внештатных сбоев и аварий. В режим аварийного обслуживания Система переходит в следующих случаях:

– *выход из строя аппаратно-программного комплекса, вызванный выходом из строя элементов аппаратной или программной базы;*

– *выход из строя сети передачи данных;*

– *другие внештатные и аварийные ситуации.*

4.1.5 Требования по диагностированию системы защиты информации

СЗИ должна предоставлять инструменты диагностирования основных процессов системы. Компоненты Системы должны предоставлять удобный интерфейс для возможности просмотра диагностических событий, мониторинга процесса выполнения программ.

При возникновении аварийных ситуаций, либо ошибок в ПО, диагностические инструменты должны позволять сохранять полный набор информации, необходимой разработчику для идентификации проблемы (снимки экранов, текущее состояние памяти, файловой системы).

4.1.6 Требования к модернизации

Модернизация СЗИ обязательна при существенном изменении действующих нормативных документов по защите информации, устаревании применяемых СрЗИ, а также при изменении основных процессов обработки информации.

4.2 Требования к функциям системы защиты информации

4.2.1 Подсистема защиты от несанкционированного доступа

Компоненты подсистемы защиты от НСД должны обладать следующими функциями:

- *функционировать в Windows системах;*
- *разграничение прав пользователей. Разграничения должны касаться доступа к объектам файловой системы (FAT и NTFS), доступа к сети, доступа к сменным накопителям. Должен быть реализован независимый от механизмов ОС механизм разграничения прав доступа к объектам файловой системы. Разграничения должны касаться всех пользователей – локальных, сетевых, доменных, терминальных;*
- *генерация сложных паролей;*
- *возможность ограничивать СрЗИ от НСД круг доступных сетевых ресурсов (с точностью до отдельных удаленных рабочих станция и отдельных папок общего доступа);*
- *аудит действий пользователей независимыми от операционной системы средствами (вход/выход, доступ к ресурсам, запуск процессов, печать документов, управление учетными записями и политиками безопасности). Должны вестись непрерывные журналы (т.е. новые записи не должны затирать более старые);*
- *возможность локального и удаленного администрирования (управление пользователями, политиками безопасности, правами доступа, аудитом; просмотр журналов);*
- *возможность периодического контроля целостности файлов и программно-аппаратной среды, а также контроля по команде администратора и по расписанию;*
- *очистку остаточной информации (принудительная зачистка определенных файлов и папок);*
- *возможность централизованного управления защищенными рабочими станциями при помощи специального модуля. С помощью этого модуля должно осуществляться централизованное управление учетными записями пользователей, политиками, правами пользователей. Также этим модулем должен осуществляться периодический сбор журналов со всех защищенных рабочих станций;*
- *возможность построения иерархии управления при помощи специального модуля менеджера, управляющего несколькими модулями централизованного управления;*
- *сигнализация и регистрация попыток НСД, и деактивации СрЗИ НСД.*

4.2.2 Подсистема антивирусной защиты

Компоненты подсистемы АВЗ должны обладать следующими функциями:

- *функционировать под управлением ОС Windows;*
- *проверять объекты файловой системы, расположенные на локальных дисках компьютера, а также смонтированные и разделяемые ресурсы, доступ к которым предоставляется по протоколам SMB / CIFS и NFS;*

– *проверка объектов файловой системы выполняется как в режиме реального времени – функция постоянной защиты, так и по требованию пользователя;*

– *обнаруживать зараженные и подозрительные объекты;*

– *обезвреживать обнаруженные в файлах угрозы;*

– *помещать подозрительные объекты на карантин;*

– *сохранять резервные копии файлов перед их антивирусной обработкой, восстанавливать файлы из резервных копий;*

– *уведомлять администратора о событиях, отражающих изменение состояния АВЗ сервера и состояния антивируса в целом;*

– *формировать статистику и отчеты о результатах работы;*

– *настраивать параметры и управлять работой программы как локально, стандартными средствами операционной системы, так и удаленно с помощью специального сервера централизованного управления;*

– *обнаружение фактов вирусного заражения при динамическом контроле, осуществляемом в процессе функционирования АРМ, а также при выполнении периодических проверок (оперативной памяти, локальных носителей информации, томов, каталогов, файлов) по запросам пользователей и/или администраторов;*

– *обнаружение фактов вирусного заражения (в том числе с применением эвристического анализа для выявления неизвестных вирусов);*

– *сигнализация администратору о фактах вирусного заражения;*

– *возможность удаления программного кода вируса из объектов, в которых он был обнаружен;*

– *возможность удаления файлов, в которых обнаружены программы-вирусы в случае, если удаление программного кода вируса и объектов невозможно;*

– *самоконтроль целостности (не инфицированности вирусом) антивирусного средства;*

– *блокирование доступа к отчуждаемым носителям информации в случае обнаружения фактов вирусного заражения;*

– *блокирование вирусных воздействий на служебные области носителей информации;*

– *возможность обновления (в том числе автоматического) баз данных признаков вредоносных компьютерных программ (вирусов);*

– *возможность централизованного управления (установка, удаление, обновление, конфигурирование, контроль актуальности версий программного обеспечения средств АВЗ, обновлением баз данных признаков вредоносных компьютерных программ) компонентами АВЗ администратором информационной безопасности из единой консоли управления АВЗ;*

– *разграничение прав доступа к средствам управления АВЗ.*

4.2.3 Подсистема обнаружения вторжений

Подсистема обнаружения вторжений может входить в состав аппаратно-программного комплекса межсетевого экрана и должна обладать следующими функциями:

– *обнаружение атак в масштабе времени близком к реальному с оповещением администратора безопасности о выявленной атаке визуально (о наиболее критичных событиях, выборочных событиях и т. д.);*

– *регистрация факта наличия атаки, типа атаки, субъекта и объекта атаки, портов, времени, критичности, пакетов, соответствующих зарегистрированному событию;*

– *свыше 15 000 сигнатур атак.*

4.2.4 Подсистема межсетевого экранирования

Компоненты подсистемы межсетевого экранирования в составе аппаратного межсетевого экрана должны обладать следующими функциями:

– *фильтрация IP-пакетов в соответствии с заданными правилами фильтрации на основе IP-адресов отправителя и получателя, протоколов, сетевых интерфейсов, номеров портов UDP/TCP, направления IP-пакетов;*

– *возможность удаленного централизованного обновления служебно-справочной информации с контролем прохождения обновления в ПО управления;*

– *возможность удаленного централизованного обновления ПО межсетевого экрана с контролем прохождения обновления;*

– *совместимость при работе с сетевым оборудованием, реализующим NAT/PAT трансляцию сетевых адресов;*

– *возможность работы при изменении собственных IP-адресов, IP-адресов NAT – устройств, возможность работы с устройствами с динамическими правилами NAT;*

– *удаленная или локальная настройка межсетевого экрана через специализированную консоль.*

4.2.5 Подсистема анализа защищенности

Подсистема анализа защищенности должна обеспечивать:

– *выявление, анализ уязвимостей Системы и оперативное устранение вновь выявленных уязвимостей;*

– *контроль установки обновлений ПО, включая обновление ПО СрЗИ;*

– *контроль работоспособности, параметров настройки и правильности функционирования ПО и СрЗИ;*

– *контроль состава ТС, ПО и СрЗИ;*

– *контроль правил генерации и смены паролей пользователей, заведения и удаления учетных записей пользователей, реализации правил разграничения доступом, полномочий пользователей в Системе.*

4.2.6 Подсистема защиты среды виртуализации

Требования не предъявляются.

4.2.7 Подсистема криптографической защиты

Компоненты подсистемы криптографической защиты должны обеспечивать:

– *защиту трафика на уровне аутентификации/шифрования сетевых пакетов по протоколам IPsec AH и/или IPsec ESP;*

– *пакетную фильтрацию трафика;*

– *контекстную фильтрацию для протоколов TCP и FTP;*

– *работу по расписанию для правил пакетной фильтрации;*

– *классификацию и маркирование трафика;*

– *различные наборы правил обработки трафика на различных интерфейсах;*

– *возможность задания независимых правил для входящего и исходящего трафиков на каждом интерфейсе, как для пакетной, так и контекстной фильтрации трафика;*

– *получение сертификатов открытых ключей по протоколу LDAP;*

– *событийное протоколирование с возможностью объединять события в группы и задавать для каждой группы свой независимый уровень протоколирования;*

– *сбор статистики для мониторинга;*

– *реализацию заданной дисциплины взаимодействия (аутентификацию и/или защиту трафика) для каждого защищенного соединения, доступ в заданном защищенном режиме только для зарегистрированных, в том числе и для мобильных средств вычислительной техники;*

– *регулируемую стойкость защиты трафика;*

– *маскировку топологии защищаемого сегмента сети (туннелирование трафика);*

– *возможность задания дополнительной аутентификации партнера на основе запросов на RADIUS сервер;*

– *загрузку политики из внешнего файла;*

– *компоненты подсистемы должны быть сертифицированы ФСБ России по требованиям к СКЗИ, предназначенным для защиты информации, не содержащей сведений, составляющих государственную тайну:*

а) класса КС1 для защиты каналов связи, выходящих за пределы КЗ, служащих для организации взаимодействия внешних пользователей с Системой;

б) класса КС3 для защиты каналов связи, выходящих за пределы КЗ, служащих для организации взаимодействия Системы с внешними информационными системами;

– *могут использоваться для криптографической защиты (шифрование и имитозащита пакетов по протоколам IPSec AH и/или IPSec ESP, криптографическая аутентификация абонентов при установлении соединения) информации, не содержащей сведений, составляющих государственную тайну.*

4.3 Требования к видам обеспечения

4.3.1 Требования к математическому обеспечению

Требования не предъявляются.

4.3.2 Требования к информационному обеспечению

Информационное обеспечение должно быть достаточным для поддержания всех автоматизируемых функций СЗИ Системы.

4.3.3 Требования к лингвистическому обеспечению

Требования не предъявляются.

4.3.4 Требования к программному обеспечению

Требования к ПО определены в п. 4.2 настоящего Технического задания.

4.3.5 Требования к техническому обеспечению

Требования к техническому обеспечению определены в п. 4.2 настоящего Технического задания.

4.3.6 Требования к метрологическому обеспечению

Требования не предъявляются.

4.3.7 Требования к организационному обеспечению

Организационное обеспечение СЗИ должно быть достаточным для эффективного выполнения сотрудником возложенных на него обязанностей при осуществлении взаимодействия с компонентами СЗИ.

Заказчиком должны быть определены структура и функции подразделений, участвующих в функционировании СЗИ, а также должны быть определены должностные лица, ответственные за:

- *обработку информации;*
- *администрирование СЗИ;*
- *обеспечение безопасности информации СЗИ.*

4.3.8 Требования к методическому обеспечению

Требования к методическому обеспечению СЗИ определяются:

- *нормативно-правовыми актами и стандартами Российской Федерации в области информационной безопасности и защиты информации;*
- *нормативно-распорядительными и методическими документами ФСТЭК России;*
- *источниками нормативно-справочной информации государственных органов исполнительной власти;*
- *ведомственными документами.*

Перечень документов, входящих в состав методического обеспечения СЗИ, приведен в разделе "Источники разработки".

4.4 Общие технические требования к системе защиты информации

4.4.1 Требования к персоналу

Операторы Системы должны пройти обучение правилам работы с информацией, обрабатываемой в Системе, выполнению требований эксплуатационной документации на Систему.

Администраторы информационной безопасности должны быть способны эксплуатировать используемые в системе СрЗИ и уметь оперативно реагировать на события информационной безопасности.

На этапе проектирования должны быть сформулированы предложения по численности администраторов информационной безопасности для обслуживания СЗИ. Эта характеристика должна зависеть от предлагаемого на этапе проектирования состава технических, программных и программно-аппаратных средств.

4.4.2 Требования к показателям назначения

Требования не предъявляются.

4.4.3 Требования к надежности

Элементы программно-аппаратных ТС СЗИ должны удовлетворять условию круглосуточной работы, а также иметь возможность восстановления в случаях сбоев.

4.4.4 Требования безопасности

4.4.4.1 Требования по обеспечению радиоэлектронной безопасности

Требования по обеспечению радиоэлектронной безопасности при монтаже, наладке, эксплуатации, обслуживании и ремонте ТС определяются ГОСТ-12.1.006.

4.4.4.2 Требования по допустимым уровням вибрационных, шумовых и акустических нагрузок

Требования по допустимым уровням вибрационных, шумовых и акустических нагрузок определяются ГОСТ 12.1.003.

4.4.5 Требования к эргономике и технической эстетике

Эргономические и гигиенические требования определяются ГОСТ 22.269 и нормами СН-21571.

4.4.6 Требования к эксплуатации, техническому обслуживанию, ремонту и сохранности компонентов системы защиты информации

Для нормальной эксплуатации разрабатываемой СЗИ Системы должно быть обеспечено бесперебойное питание защищаемых АРМ и серверов. При эксплуатации СЗИ должна быть обеспечена соответствующая стандартам хранения и эксплуатации ТС температура и влажность воздуха, в соответствии с эксплуатационной документацией на эти ТС.

Периодическое техническое обслуживание используемых компонентов СЗИ должно проводиться в соответствии с требованиями технической документации изготовителей на СрЗИ, но не реже одного раза в год.

Периодическое техническое обслуживание и тестирование компонентов СЗИ должны включать в себя обслуживание и тестирование всех используемых средств, включая рабочие АРМ, серверы, кабельные системы и сетевое оборудование, устройства бесперебойного питания.

В процессе проведения периодического технического обслуживания должны проводиться внешний и внутренний осмотр и чистка ТС, проверка контактных соединений, проверка параметров настроек работоспособности ТС и тестирование их взаимодействия.

Восстановление работоспособности ТС должно проводиться в соответствии с инструкциями разработчика и поставщика СрЗИ и документами по восстановлению работоспособности ТС и завершаться проведением их тестирования. Размещение помещений и их оборудование должны исключать возможность бесконтрольного проникновения в них посторонних лиц и обеспечивать сохранность находящихся в этих помещениях ТС.

Все пользователи Системы должны соблюдать правила эксплуатации ТС и оборудования СЗИ.

4.4.7 Требования по сохранности информации при аварии

Сохранность информации в Системе должна быть обеспечена в случае возникновения следующих ситуаций:

- *отказ отдельных ТС СЗИ;*
- *нарушение целостности ПО Системы;*
- *проведение ремонтных и регламентных работ с оборудованием Системы, инженерных систем, как на месте, так и в сторонних организациях;*
- *проведение ремонтных работ в помещении, где размещается Система;*
- *потеря электропитания от промышленной сети электропитания объектов.*

Сохранность информации должна быть обеспечена комплексом организационных и/или технических мер и СрЗИ.

Порядок действия при возникновении нештатных ситуаций, проведении ремонтных и регламентных работ должен быть определен в эксплуатационной документации на Систему.

4.4.8 Требования к патентной чистоте

Все средства СЗИ должны обладать патентной чистотой и иметь возможность легального использования на территории Российской Федерации.

4.4.9 Требования к стандартизации и унификации

В составе СЗИ должны применяться только серийно выпускаемые программные и ТС.

4.4.10 Дополнительные требования

Требования не предъявляются.

5 Состав и содержание работ по созданию системы защиты информации

5.1 Требования к составу работ

Работы по созданию СЗИ Системы включают следующие этапы:

1) разработка СЗИ Системы;

2) внедрение СЗИ Системы;

3) оценка соответствия Системы требованиям о защите информации.

5.2 Требования к содержанию работ

Требования к содержанию работ по созданию СЗИ Системы приведены в таблице 6.

Таблица 6 – Требования к содержанию работ по созданию СЗИ

№ п/п	*Наименование работ*	*Содержание работ*
1.	*Формирование требований к защите информации, содержащейся в Системе*	*классификация Системы по требованиям защиты информации*
		определение угроз безопасности информации
		определение требований к СЗИ Системы
2.	*Разработка СЗИ Системы*	*проектирование СЗИ Системы*
		разработка эксплуатационной документации на СЗИ Системы
3.	*Внедрение СЗИ Системы*	*подготовка инфраструктуры к вводу СЗИ*
		разработка организационно-распорядительной документации
		оснащение Системы ТС, ПО, СрЗИ
		проведение предварительных испытаний СЗИ Системы
		анализ уязвимостей Системы и принятие мер защиты информации по их блокированию (нейтрализации)
4.	*Оценка соответствия Системы требованиям о защите информации*	*проведение комплекса организационных и технических мероприятий, в результате которых подтверждается соответствие СЗИ Системы*

5.3 Сроки выполнения работ

Сроки выполнения работ по разработке СЗИ Системы определяются _____.

6 Порядок разработки системы защиты информации

Порядок проведения работ по созданию СЗИ приведен в таблице 7.

Таблица 7 – Состав и содержание работ

№ п/п	*Наименование этапа*	*Требования к содержанию работ*	*Отчетная документация*
1.	*Формирование требований к защите информации, содержащейся в Системе*	*классификация Системы по требованиям защиты информации*	*акт определения уровня защищенности ПДн, обрабатываемых в Системе*
		определение угроз безопасности информации	*модель угроз и нарушителя безопасности информации Системы*
		определение требований к СЗИ Системы	*техническое задание на создание СЗИ Системы;* *акт сдачи-приемки выполненных работ по этапу*
2.	*Разработка СЗИ Системы*	*проектирование СЗИ Системы*	*пояснительная записка к техническому проекту на СЗИ Системы*
		разработка эксплуатационной документации на СЗИ Системы	*эксплуатационная документация на СЗИ Системы;* *акт сдачи-приемки выполненных работ по этапу*
3.	*Внедрение СЗИ Системы*	*установка и настройка СрЗИ в Системе*	*акт приема-передачи поставленного товара;* *акт приема-передачи неисключительных прав (лицензий);* *лицензионное (сублицензионное) соглашение;* *акты установки СрЗИ*
		разработка организационно-распорядительной документации	*организационно-распорядительная документация на Систему;* *описание технологического процесса обработки информации в Системе;* *технический паспорт Системы*
		предварительные испытания СЗИ Системы	*протоколы и акты предварительных испытаний*
		анализ уязвимостей Системы и принятие мер защиты информации по их устранению	*заключение по результатам анализа уязвимостей Системы*
4.	*Оценка соответствия Системы требованиям о защите информации*	*проведение комплекса организационных и технических мероприятий, в результате которых подтверждается соответствие СЗИ Системы*	*протокол оценки соответствия требованиям о защите информации;* *заключение о соответствии Системы требованиям о защите информации*

7 Порядок контроля и приемки системы защиты информации

7.1 Общие требования к порядку контроля и приемки системы защиты информации

Испытания проводятся с целью проверки СЗИ Системы на соответствие настоящим требованиям и включают в себя:

- *проведение предварительных испытаний;*
- *проведение опытной эксплуатации;*
- *проведения приемочных испытаний.*

7.1.1 Предварительные испытания

По результатам настройки СрЗИ, эксплуатируемых в СЗИ Системы, производится проведение предварительных испытаний СЗИ Системы, на основании утвержденного Оператором документа "Программа и методики предварительных испытаний", по результатам которых составляется следующая отчетная документация:

- *протокол предварительных испытаний СЗИ Системы;*
- *акт предварительных испытаний СЗИ Системы.*

В случае отрицательного заключения по результатам предварительных испытаний, Исполнитель, совместно с Заказчиком устраняет выявленные нарушения, и проводит предварительные испытания повторно, до достижения положительного заключения.

7.1.2 Опытная эксплуатация

По результатам предварительных испытаний, проводится опытная эксплуатация СЗИ Системы, на основании утвержденного Оператором документа "Программа и методики опытной эксплуатации", по результатам которой составляется следующая отчетная документация:

- *протокол опытной эксплуатации СЗИ Системы;*
- *акт о завершении опытной эксплуатации СЗИ Системы.*

В случае отрицательного заключения по результатам опытной эксплуатации, Исполнитель, совместно с Заказчиком устраняет выявленные нарушения, и проводит опытную эксплуатацию повторно, до достижения положительного заключения.

7.1.3 Приемочные испытания

По завершению опытной эксплуатации СЗИ производятся приемочные испытания. По результатам приемочных испытаний составляется следующая отчетная документация:

- *протокол приемочных испытаний СЗИ Системы;*
- *акт о приемки СЗИ Системы в эксплуатацию.*

В случае отрицательного заключения по результатам приемочных испытаний, Исполнитель, совместно с Заказчиком устраняет выявленные нарушения, и проводит приемочные испытания повторно, до достижения положительного заключения.

8 Требования к составу и содержанию работ по подготовке объекта автоматизации к вводу системы защиты информации в действие

При подготовке к вводу СЗИ Системы в действие должны быть выполнены мероприятия, обеспечивающие соответствие создаваемой СЗИ Системы требованиям, содержащимся в настоящем Техническом задании.

Лица, доступ которым к ИОД, не содержащей сведения, составляющие государственную тайну, обрабатываемой на Объекте, необходим для выполнения служебных обязанностей, должны допускаться к соответствующей информации на основании списка, утвержденного уполномоченным лицом Заказчика.

Уполномоченное лицо Заказчика согласует и утверждает организационно-распорядительную документацию по защите информации для обеспечения защиты информации на Объекте в ходе его эксплуатации.

Размещение оборудования и охрана помещений, в которых ведется работа с ИОД, не составляющей государственную тайну, должны обеспечивать сохранность машинных носителей информации и СрЗИ, а также исключать возможность неконтролируемого пребывания и (или) проникновения посторонних лиц.

Размещений устройств ввода информации средств вычислительной техники, информационно-вычислительных комплексов, технических средств обработки информации, входящих в состав Объекта, должно осуществляться таким образом, чтобы была исключена возможность просмотра посторонними лицами защищаемой информации.

Должно быть проведено обучение персонала, обслуживающего СЗИ Системы в соответствии с выполняемыми ими обязанностями.

9 Требования к документированию

9.1 Перечень подлежащих разработке документов

Перечень подлежащих разработке документов определен в разделе 6 настоящего Технического задания.

9.2 Вид представления и количество документов

Разработанные документы должны быть переданы Исполнителем работ Заказчику на бумажном носителе с печатью Исполнителя работ в 1 (одном) экземпляре и на машинном носителе информации в формате электронных файлов Microsoft Word (.doc, *.docx) или LibreOffice (*.odt) в 1 (одном) экземпляре.*

9.3 Требования по использованию единой системы конструкторской документации и единой системы программной документации при разработке документов

Требования по использованию единой системы конструкторской документации и единой системы программной документации при разработке документов не предъявляются.

10 Источники разработки

Перечень документов, используемых при создании СЗИ Системы:

- *Федеральный закон от 27.07.2006 № 149-ФЗ "Об информации, информационных технологиях и о защите информации";*
- *Федеральный закон от 27.07.2006 № 152-ФЗ "О персональных данных";*
- *Постановление Правительства Российской Федерации от 01.11.2012 № 1119 "Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных";*
- *Приказ ФСБ России от 10.07.2014 № 378 "Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищенности";*
- *Приказ ФСТЭК России от 18.02.2013 № 21 "Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных";*
- *Методический документ ФСТЭК России от 11.02.2014 "Меры защиты информации в государственных информационных системах";*
- *ГОСТ 34.602-2020 "Информационная технология. Комплекс стандартов на автоматизированные системы. Техническое задание на создание автоматизированной системы";*
- *ГОСТ Р 50628-2000 "Совместимость технических средств электромагнитная. Устойчивость машин электронных вычислительных персональных к электромагнитным помехам";*
- *ГОСТ Р 51275-2006 "Защита информации. Факторы, воздействующие на информацию. Общие положения";*
- *ГОСТ Р 51583-2014 "Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения";*
- *ГОСТ Р 56103-2014 "Защита информации. Автоматизированные системы в защищенном исполнении. Организация и содержание работ по защите от преднамеренных силовых электромагнитных воздействий. Общие положения";*
- *ГОСТ 12.2.003 "Система стандартов безопасности труда. Оборудование производственное. Общие требования безопасности";*
- *ГОСТ 12.2.007 "Система стандартов безопасности труда. Изделия электротехнические. Общие требования безопасности";*
- *ГОСТ 27201-87 "Машины вычислительные электронные персональные. Типы, основные параметры, общие технические требования".*

Лист регистрации изменений									
Изм.	*Номера листов (страниц)*				*Всего листов (страниц) в докум.*	*№ документа*	*Входящий № сопроводительного докум. и дата*	*Подп.*	*Дата*
	изменен-ных	*заменен-ных*	*новых*	*анну-лиро-ванных*					

ЛИСТ СОГЛАСОВАНИЯ

Наименование организации, предприятия	*Должность исполнителя*	*Фамилия, имя, отчество*	*Подпись*	*Дата*